

CVE-2022-45658 writeup

修复环境

使用fw2tar从.bin中提取文件系统

```
fw2tar US_AC6V1.0BR_V15.03.05.19_multi_TD01.bin
```

发现会对 br0 网卡检查, 如果 br0 存在则绑定到 br0 而不是 0.0.0.0

```
85  if ( getIfIp((int)"br0:dname", (int)v36) >= 0 )
86      v6 = sub_4194C(v36);
87  else
88      v6 = sub_4194C("0.0.0.0");
```

添加 br0 网卡如下:

```
sudo ip link add name br0 type bridge
sudo ip link set br0 up
sudo ip addr add 192.168.50.1/24 dev br0
```

启动 httpd:

```
sudo chroot ./ ./qemu-arm-static ./bin/httpd
```

启动后卡住, 卡在检查网络

```
28  init_core_dump(v2);
29  puts("\n\nYes:\n\n      ***** WeLoveLinux***** \n\n Welcome to ...");
30  sub_305FC();
31  while ( check_network((int)v19) <= 0 )
32      sleep(1u);
33  v3 = sleep(1u);
34  if ( ConnectCfm(v3) )
35  {
36      sub_100D8(0, 61440, 1);
37      memset(s, 0, sizeof(s));
38      if ( !GetValue("lan.webiplansslen", s) )
39          strcpy(s, "0");
40      sslenable = atoi(s);
41      if ( !GetValue("lan.webport", s) )
42          strcpy(s, "80");
43      if ( !GetValue("lan.webipen", dest) )
44          strcpy((char *)dest, "0");
45      if ( !GetValue("lan.webip", dest) )
46          strcpy((char *)dest, "1");
```

进行 patch:

```

28 init_core_dump(v2);
29 puts("\n\nYes:\n\n      ***** WeLoveLinux***** \n\n Welcome to ...");
30 sub_305FC();
31 check_network((int)v19);
32 v3 = sleep(1u);
33 if ( ConnectCfm(v3) )
34 {
35     sub_100D8(0, 61440, 1);
36     memset(s, 0, sizeof(s));
37     if ( !GetValue("lan.webiplansslen", s) )
38         strcpy(s, "0");

```

config.yaml

```

static_files:
  /etc_ro/init.d/rcs:
    type: host_file
    host_path: ./base/fs/etc_ro/init.d/rcs
  /bin/httpd:
    type: host_file
    host_path: ./base/fs/bin/httpd_patch

```

运行后出现 Connect to server failed.

```

init_core_dump 1816: rlim_cur = -1, rlim_max = -1
init_core_dump 1825: open core dump success
init_core_dump 1834: rlim_cur = 5242880, rlim_max = 5242880

Yes:

      ***** WeLoveLinux*****

Welcome to ...
connect: No such file or directory
Connect to server failed.

```

继续patch

```

25  memset(v17, 0, sizeof(v17));
26  v15 = 0;
27  init_core_dump(v2);
28  puts("\n\nYes:\n\n      ***** WeLoveLinux***** \n\n Welcome to ...");
29  sub_305FC();
30  check_network((int)v18);
31  sleep(1u);
32  sub_100D8(0, 61440, 1);
33  memset(s, 0, sizeof(s));
34  atoi(s);
35  if ( !strcmp((const char *)dest, "1") )
36  {
37      sslport = atoi(s);
38      port = atoi(s);
39  }
40  LanIfName = getLanIfName();
41  if ( getIfIp(LanIfName, v17) < 0 )
42  {
43      GetValue((int)"lan.ip", (int)s);
44      strcpy(g_lan_ip, s);
45      memset(s_1, 0, sizeof(s_1));
46      if ( !tpi_lan_dhcpc_get_ipinfo_and_status(s_1) && s_1[0] )
47          vos_strcpy(g_lan_ip, s_1);
48  }
49  else

```

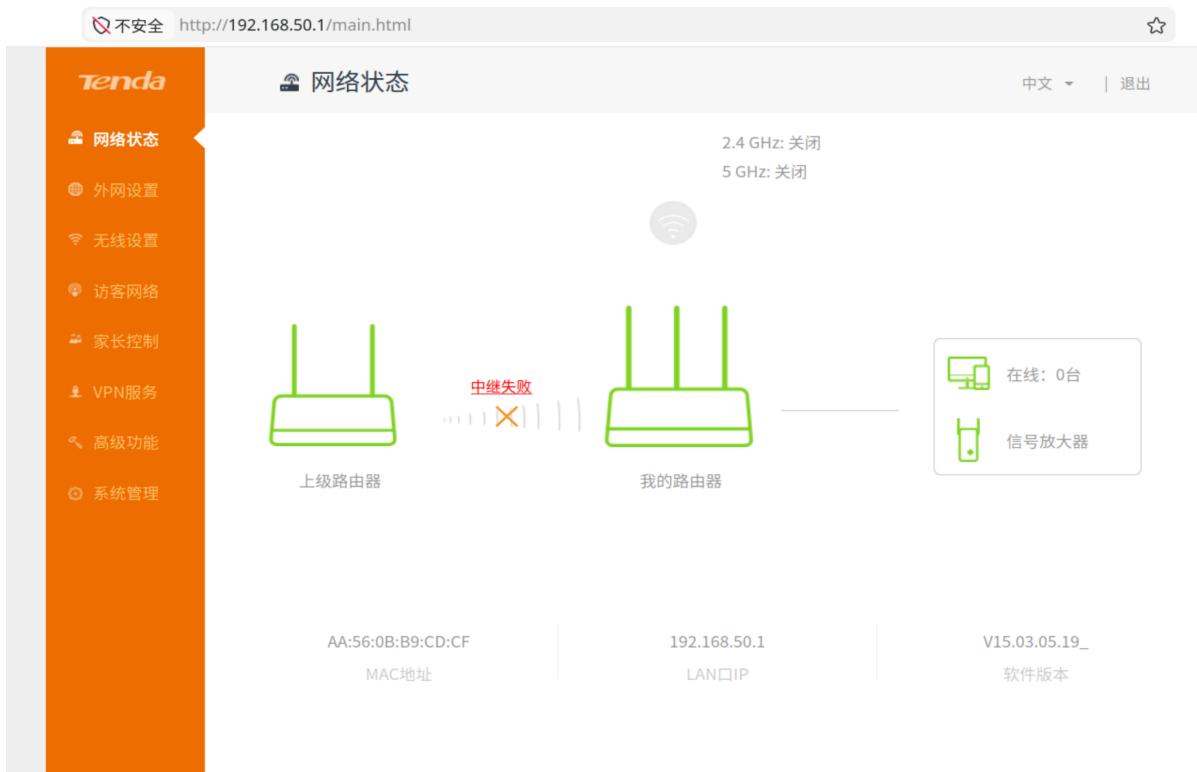
现在启动成功但是404



检查启动脚本 /etc/init.d/rcS, 里面有拷贝 webroot 的操作

```
cp -rf /webroot_ro/* /webroot/
```

将 webroot_ro/ 目录下内容拷贝过去, 这次启动成功出现主页面



漏洞点

运行poc, 会在 strcpy 中因拷贝到未映射内存而 SIGSEGV

```
*R0 0x11fee2 ← 0x61616161 ('aaaa')
*R1 0x40a7012f ← 0x61616161 ('aaaa')
*R2 0x61
*R3 0x120000
R4 0xfab18 → 0xfa9d0 ← 1
R5 0x11be00 ← '/goform/openSchedWifi'
R6 1
R7 0x40800604 ← './bin/httpd_patch'
R8 0xe968 (_init) ← mov r12, sp
R9 0x2e128 ← push {r4, r11, lr}
R10 0x40800438 ← 0
R11 0x408000e4 → 0x16ed0 (websFormHandler+336) ← mov r3, #1
*R12 0xfaf60 (strcpy@got[plt]) → 0x40a2a508 ← mov r3, r0
SP 0x407ffe60 → 0x40800010 ← 0
LR 0x8d0ac (setSchedWifi+904) ← mov r3, #0
*PC 0x40a2a514 ← strb r2, [r3], #1

[ DISASM / arm / arm mode / set emulate on ]
0x40a2a514 strb r2, [r3], #1 <Cannot dereference [0x120000]>
0x40a2a518 bne 0x40a2a53c <0x40a2a53c>
0x40a2a51c bx lr
0x40a2a520 push {r4, lr}
0x40a2a524 mov r3, r0
0x40a2a528 b 0x40a2a550 <0x40a2a550>
↓
0x40a2a550 ldrb r12, [r3]
0x40a2a554 cmp r12, #0
0x40a2a558 bne 0x40a2a53c <0x40a2a53c>
0x40a2a55c rsb r0, r0, r3
0x40a2a560 pop {r4, pc} <0x40a2a568>
[ STACK ]
00:0000 sp 0x407ffe60 → 0x40800010 ← 0
01:0004 0x407ffe64 ← 0x80
02:0008 0x407ffe68 ← 0x80
03:000c 0x407ffe6c ← 0x61616161 ('aaaa')
04:0010 0x407ffe70 ← 0x61616161 ('aaaa')
sudo sudo .../ac6/US_AC6V1.0BR_V15.03.05.19_multi_T001/fs
```

向前追踪到malloc, 发现只分配了0x19: `malloc(0x19)`

```

*R6 1
*R7 0x40800404 ← './bin/httpd_patch'
*R8 0xe968 (_init) ← mov r12, sp
*R9 0x2e128 ← push {r4, r11, lr}
*R10 0x40800438 ← 0
*R11 0x408000e4 → 0x16ed0 (websFormHandLer+336) ← mov r3, #1
*R12 0x408cfedc → 0x408c5a50 ← mov r3, r0
*SP 0x407ffe60 ← 0x61616161 ('aaaa')
LR 0x408c4bf0 ← mov r0, r6
*PC 0x8cf0c (setSchedWifi+488) ← bl malloc@plt

[ DISASM / arm / arm mode / set emulate on ]
↳ 0x8cf0c <setSchedWifi+488> bl malloc@plt [ malloc@plt ]
size: 0x19

0x8cf10 <setSchedWifi+492> mov r3, r0
0x8cf14 <setSchedWifi+496> str r3, [r11, #-0x30]
0x8cf18 <setSchedWifi+500> ldr r0, [r11, #-0x1c]
0x8cf1c <setSchedWifi+504> bl atoi@plt [ atoi@plt ]

0x8cf20 <setSchedWifi+508> str r0, [r11, #-0x18]
0x8cf24 <setSchedWifi+512> sub r3, r11, #0x154
0x8cf28 <setSchedWifi+516> sub r2, r11, #0x154
0x8cf2c <setSchedWifi+520> add r2, r2, #0x80
0x8cf30 <setSchedWifi+524> str r2, [sp]
0x8cf34 <setSchedWifi+528> mov r2, #0x80 R2 ⇒ 0x80

[ STACK ]
00:0000 sp 0x407ffe60 ← 0x61616161 ('aaaa')
01:0004 0x407ffe64 ← 0x61616161 ('aaaa')
02:0008 0x407ffe68 ← 0x61616161 ('aaaa')
03:000c 0x407ffe6c ← 0x61616161 ('aaaa')
04:0010 0x407ffe70 ← 0x61616161 ('aaaa')
05:0014 0x407ffe74 ← 0x61616161 ('aaaa')
06:0018 0x407ffe78 ← 0x61616161 ('aaaa')
07:001c 0x407ffe7c → 0x40a6c010 ← 0x65686373 ('sche')

[ BACKTRACE ]
↳ 0 0x8cf0c setSchedWifi+488
1 0x16ed0 websFormHandLer+336
2 0x17d7c None
sudo sudo .../ac6/US_AC6V1.0BR_V15.03.05.19_multi_TD01/fs

```

总结伪代码如下：

```

ptr = malloc(0x19u);
// ...
strcpy((char *)ptr + 10, schedEndTime); // <--- crash

```

所以漏洞点就是未限制拷贝长度导致的堆溢出

拷贝源是用户控制的参数schedEndTime

结果

该漏洞可导致向高地址无限拷贝，最终尝试写入未映射内存而 SIGSEGV 崩溃，导致 DOS

由于可以向更高地址的堆无限写入，可以考虑篡改相邻堆块的 metadata，触发 unlink 实现任意地址分配，通过 free ptr 没法触发，因为堆块大小在 fastbin 内。